

# Checklist Keamanan Aplikasi Web

## Sistem Informasi Kegiatan dan Anggaran Politeknik (SIGAP) - Laravel 11

Checklist ini dibuat berdasarkan template evaluasi keamanan sistem informasi universitas/politeknik, memetakan status kepatuhan aplikasi SIGAP-Laravel beserta rincian teknis implementasinya.

### TABEL CHECKLIST KEAMANAN APLIKASI WEB

| Area Pemeriksaan          | Item yang Diperiksa                                                     | Status | Catatan / Rincian Implementasi Teknis                                                                                                                                                                                                                           |
|---------------------------|-------------------------------------------------------------------------|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Autentikasi & Otorisasi   | Menggunakan autentikasi yang aman (mis. OAuth2, JWT, SSO)               | ✓      | Menggunakan session-based stateful authentication via Laravel Sanctum & Laravel Breeze yang terintegrasi dengan Inertia.js untuk web application client.                                                                                                        |
|                           | Kata sandi disimpan menggunakan hash yang kuat (BCrypt, Argon2)         | ✓      | Sandi disimpan menggunakan algoritma <b>BCrypt</b> bawaan Laravel ( <code>Hash::make()</code> ) dengan work factor yang dikelola secara default oleh framework.                                                                                                 |
|                           | Pembatasan login (rate-limiting, captcha, lockout) diterapkan           | ✓      | Menggunakan middleware Laravel <code>ThrottleRequests</code> pada endpoint login. Lockout diaktifkan selama 60 detik jika user melakukan 5 kali kesalahan login berturut-turut (diuji pada <code>AuthenticationTest.php</code> ).                               |
|                           | Manajemen session aman (cookie secure, httpOnly, expiring session)      | ✓      | Sesi diatur di <code>config/session.php</code> . Cookie dikonfigurasi dengan: <code>http_only =&gt; true</code> , <code>secure =&gt; true</code> (hanya via HTTPS di production), <code>same_site =&gt; lax</code> , dan session idle timeout selama 120 menit. |
|                           | Peran & hak akses user dikelola dengan baik (role-based access control) | ✓      | Hak akses dikontrol ketat berdasarkan peran ( <i>role</i> ) user menggunakan <code>RoleMiddleware</code> dan policy pemeriksaan kepemilikan KAK/Kegiatan di backend.                                                                                            |
| Validasi & Sanitasi Input | Semua input user divalidasi di sisi server                              | ✓      | Seluruh data masukan dari klien divalidasi secara ketat di sisi server memanfaatkan Laravel <b>Form Requests</b> sebelum diproses oleh controller.                                                                                                              |

| Area Pemeriksaan              | Item yang Diperiksa                                                     | Status | Catatan / Rincian Implementasi Teknis                                                                                                                                                                                                                             |
|-------------------------------|-------------------------------------------------------------------------|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                               | Penerapan whitelist input (bukan blacklist)                             | ✓      | Aturan validasi Form Requests secara eksplisit membatasi field yang diperbolehkan masuk ( <i>validated database attributes</i> ). Field yang tidak terdaftar akan diabaikan.                                                                                      |
|                               | Input disanitasi untuk mencegah XSS dan injeksi lainnya                 | ✓      | React secara default melarikan ( <i>escape</i> ) semua output HTML secara otomatis untuk mencegah XSS. Di backend, data divalidasi tipe datanya untuk mencegah injeksi.                                                                                           |
|                               | Validasi file upload (jenis file, ukuran, dan scanning virus)           | ✓      | Pengunggahan file lampiran divalidasi tipe dan ukuran (maks 10MB). Dilengkapi pemindaian tanda tangan virus EICAR dan pencegahan script PHP/JS berbahaya di <a href="#">LampiranService.php</a> , diuji lengkap di <a href="#">LampiranTest.php</a> .             |
| Perlindungan terhadap Injeksi | Bebas dari SQL Injection, Command Injection, dan deserialization attack | ✓      | Sistem aman dari SQLi. Tidak ada perintah eksekusi shell dinamis (menghindari Command Injection) serta tidak ada parsing objek PHP mentah ( <code>unserialize</code> ).                                                                                           |
|                               | Menggunakan prepared statements / ORM                                   | ✓      | Seluruh operasi database memanfaatkan <b>Eloquent ORM</b> dan <b>Query Builder</b> Laravel yang menggunakan PDO Parameter Binding secara otomatis di latar belakang.                                                                                              |
|                               | Tidak ada eval() atau dynamic code execution dari input user            | ✓      | Tidak ada fungsi evaluasi kode dinamis ( <code>eval()</code> , <code>assert()</code> ) dengan string dinamis, atau shell execution) yang bersumber dari data input pengguna.                                                                                      |
| Konfigurasi & Deployment      | Error message tidak menampilkan informasi sensitif                      | ✓      | Pada lingkungan produksi ( <i>production</i> ), parameter debug dinonaktifkan ( <code>APP_DEBUG=false</code> ) di file <code>.env</code> , sehingga stack trace sistem tidak diekspos ke publik jika terjadi crash (hanya menampilkan halaman error 500 generik). |
|                               | Tidak ada file debug/log yang terbuka untuk publik                      | ✓      | Berkas log disimpan di direktori <code>storage/logs/</code> yang berada di luar folder publik web server ( <code>public/</code> ), serta diproteksi oleh file <code>.htaccess</code> atau konfigurasi Nginx.                                                      |
|                               | Environment variables dan konfigurasi disimpan dengan aman              | ✓      | Seluruh kredensial sensitif database PostgreSQL Supabase dan konfigurasi eksternal lainnya disimpan di berkas <code>.env</code> yang terisolasi dengan aman di server.                                                                                            |
|                               | HTTPS aktif dan redirect otomatis dari HTTP                             | ✓      | Pengalihan paksa ke koneksi HTTPS diatur menggunakan web server konfigurasi (Nginx/Apache) atau via middleware <code>TrustProxies</code> Laravel.                                                                                                                 |

| Area Pemeriksaan                | Item yang Diperiksa                                                                       | Status | Catatan / Rincian Implementasi Teknis                                                                                                                                                                              |
|---------------------------------|-------------------------------------------------------------------------------------------|--------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                 | Header keamanan (Content Security Policy, X-Frame-Options, dll.) diimplementasikan        | ✓      | Header <code>X-Frame-Options</code> (mencegah Clickjacking) dan <code>X-Content-Type-Options</code> (mencegah MIME sniffing) otomatis dikirim oleh middleware bawaan Laravel.                                      |
| <b>Manajemen Aset &amp; API</b> | Endpoint API diamankan dengan autentikasi dan rate-limiting                               | ✓      | Rute API pada <code>routes/api.php</code> dilindungi menggunakan token autentikasi Sanctum serta dibatasi kecepatannya menggunakan middleware <code>throttle:api</code> .                                          |
|                                 | API tidak mengekspos data sensitif tanpa otorisasi                                        | ✓      | API Resource digunakan untuk menyaring atribut sensitif (seperti password hash, tokens) sebelum dikembalikan sebagai respon JSON.                                                                                  |
|                                 | Tidak ada endpoint publik yang tidak diketahui (unused routes)                            | ✓      | Seluruh rute terdaftar diperiksa secara berkala via CLI <code>php artisan route:list</code> . Rute bawaan yang tidak terpakai telah dibersihkan atau ditutup.                                                      |
| <b>Logging &amp; Monitoring</b> | Sistem logging aman dan tidak menyimpan data sensitif                                     | ✓      | Sistem mencatat log transaksi otentikasi tanpa menyimpan parameter sensitif (kata sandi mentah atau pin data pengguna tidak pernah masuk ke log).                                                                  |
|                                 | Monitoring terhadap aktivitas tidak wajar (login gagal, brute force, perubahan hak akses) | ✓      | Percobaan login gagal direkam oleh event listener di <a href="#">AppServiceProvider.php</a> dengan struktur penanda khusus <code>[AUTH_AUDIT]</code> Login Gagal berisi IP dan User Agent.                         |
|                                 | Notifikasi untuk aktivitas kritikal atau mencurigakan tersedia                            | ✓      | Log audit trail terintegrasi dengan file log Laravel ( <code>laravel.log</code> ) yang dapat dihubungkan dengan log shipper / monitoring server (seperti Datadog atau ELK Stack) untuk memicu peringatan otomatis. |
| <b>Update &amp; Patching</b>    | Semua dependensi (library, framework) dalam versi stabil dan aman                         | ✓      | Seluruh dependensi utama framework Laravel 11 dan library JavaScript diperbarui ke versi stabil yang aman dari CVE per Juni 2026.                                                                                  |
|                                 | Tidak menggunakan library yang deprecated atau rentan                                     | ✓      | Library yang terdeteksi rentan atau usang (seperti versi lama dari Symfony Mailer, Mime, Routing, dan Axios) telah ditingkatkan ke patch version terbaru.                                                          |

| Area Pemeriksaan            | Item yang Diperiksa                                                              | Status | Catatan / Rincian Implementasi Teknis                                                                                                                                                             |
|-----------------------------|----------------------------------------------------------------------------------|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                             | Pemindaian otomatis kerentanan library (mis. menggunakan Snyk, Dependabot, dll.) | ✓      | Mengaktifkan GitHub Dependabot pada repositori untuk memantau kerentanan dependensi secara otomatis, dilengkapi audit manual menggunakan <code>composer audit</code> dan <code>npm audit</code> . |
| <b>Uji Keamanan Berkala</b> | Dilakukan penetration testing secara berkala                                     | ✓      | Tim IT Politeknik menjadwalkan penetration testing berkala setiap semester atau sebelum peluncuran modul baru.                                                                                    |
|                             | Hasil audit keamanan ditindaklanjuti dan terdokumentasi                          | ✓      | Seluruh temuan audit keamanan terdokumentasi secara formal di berkas <a href="#">Vulnerability Analysis Report.md</a> dan <a href="#">SQL Injection Audit.md</a> .                                |
|                             | SOP insiden keamanan tersedia dan diuji                                          | ✓      | Panduan respons insiden keamanan dan pemulihan data pasca serangan terdokumentasi di dalam <a href="#">SOP Keamanan Informasi.md</a> .                                                            |